

Developer SRS

Loan Service Provider Platform: Core Build

Version	1.3 (Final: LSP model with partner NBFC)
Date	03 October 2026
Stack	ReactJS, Tailwind CSS, Python FastAPI, PostgreSQL
Build approach	Business type confirmed: Lending Service Provider (LSP) tied up with an NBFC. Company-specific content comes from a config file.

1. Overview

A loan lead-generation and lead-management platform for a Lending Service Provider (LSP). The company is tied up with an NBFC, which is the lender. The company does not lend itself. A customer learns about loans, checks EMI and eligibility, applies without login, then creates an account to upload documents and track status. The company team (Manager, Staff, Admin) handles leads through a role-based panel and monitors performance through reports. Applying is free; no payment gateway is included.

1.1 End-to-end flow

#	Stage	Actor	What happens
1	Website	Customer	Visits public site
2	Loan information	Customer	Reads loan types, rates, tenure, eligibility, documents
3	EMI / Eligibility	Customer	Uses EMI calculator and eligibility checker
4	Apply for loan	Customer	Fills short form (name, mobile, email, city, loan type, amount, income)
5	Validation	System	Server validation, captcha and duplicate check
6	Application	System	Application created, number generated
7	Document upload	Customer	Logs in and uploads KYC and income documents
8	Application submitted	System	Confirmation page, emails sent, team notified
9	Customer dashboard	Customer	Login with email and password, sees all applications
10	Track status	Customer	Sees status timeline
11	Admin panel	Team	Secure login, dashboard, all leads
12	Assign lead	Manager	Assigns lead to a staff member
13	Handle customer	Staff	Calls customer, verifies documents, adds notes
14	Status updates	Staff	Moves application through statuses, customer is notified
15	Monitor	Manager/Admin	Tracks team workload and pending follow-ups
16	Reports	Manager/Admin	Conversion, city, loan type and staff reports, export

1.2 Build strategy

- **Core (build now):** all functional modules in this document.
- **Config-driven content:** company details, partner NBFC, Grievance Officer, consent wording, theme. Keep these in `siteConfig.js` and content files so they can change without touching code.
- Never state that the company is "RBI registered" or an NBFC. It is an LSP and the partner NBFC is the lender.

1.3 Company config

Config shape: `businessType`, `companyName`, `address`, `cin`, `contact` (phone, whatsapp, email), `partnerNbfc` (name, url, logo), `grievanceOfficer` (name, email, phone), `theme` (blue or green). All company text on the site reads from this config. Do not hardcode company details in components.

1.4 LSP compliance content

- Show the partner NBFC (lender) name and website link on Home, Loans, About and footer.
- State clearly that the company is a lending service provider and that loans are sanctioned and disbursed by the partner NBFC.
- Show Grievance Officer details (name, email, optional phone) on the Contact page and footer.
- Privacy policy and a consent checkbox at apply. Store consent time and the version of the consent text.

- Show the line: "We do not charge any advance or processing fee." Customers never pay fees to the company.
- Collect only the data that is needed. Keep documents private. No public file URLs.
- Rates are indicative and come from the NBFC rate sheet. Never copy rates or text from another provider.
- Final wording of these items is to be confirmed with the partner NBFC and the client's legal adviser.

2. Roles and Permissions

Capability	Customer	Staff	Manager	Admin
View public pages, apply	Yes	-	-	-
View own applications and documents	Yes	-	-	-
View assigned leads	-	Yes	Yes	Yes
View all leads	-	-	Yes	Yes
Assign / reassign leads	-	-	Yes	Yes
Update status, add notes, follow-ups	-	Own leads	All leads	All leads
View customer documents	Own	Assigned leads	All	All
Add lead manually	-	Yes	Yes	Yes
Reports and CSV export	-	-	Yes	Yes
Manage staff and managers	-	-	-	Yes
Edit loan types and rates	-	-	-	Yes
View audit log	-	-	-	Yes

Roles are stored in users.role (customer, staff, manager, admin) and in the JWT. Enforce on the backend with a dependency such as `require_role(...)` and on object level (staff can open only assigned leads). A Super Admin role is deferred.

3. Functional Requirements

3.1 Public website (Stages 1-2)

ID	Requirement
FR-01	Home page: hero, Apply Now, EMI calculator, loan types, how it works, FAQ.
FR-02	About Us: company story, mission, CIN (from config). Do not invent years of experience or claims.
FR-03	Loans page: all loan types with rate, amount, tenure, eligibility, documents, fees. Data comes from the loan_types table, not hardcoded. Seed all types: personal, home, business, education, gold, loan against property. Admin can switch types on or off, so only products the partner NBFC offers are shown. Rates are indicative ("starting from") and come from the NBFC rate sheet.
FR-04	Contact page: contact form, call-back request, phone, email, address, map, and a Grievance Officer block (name, email, optional phone).
FR-05	Legal page: privacy policy, terms, disclaimer. Footer shows the "no advance fee" line, the partner NBFC name and the Grievance Officer details.
FR-06	WhatsApp chat button on all pages. Responsive layout. SEO titles and descriptions.

3.2 EMI calculator and eligibility checker (Stage 3)

ID	Requirement
FR-07	EMI calculator with sliders: amount, rate, tenure. Output: monthly EMI, total interest, total payable. Formula: $EMI = P \times r \times (1+r)^n / ((1+r)^n - 1)$, $r = \text{annual rate} / 12 / 100$. Frontend only.

ID	Requirement
FR-08	Default rate and limits per loan type come from the loan types API.
FR-09	Eligibility checker inputs: age, monthly income, city, existing EMI, loan type. Rule-based estimate: max EMI = income x FOIR (default 50%) minus existing EMI, converted to a loan amount using the loan type's rate and max tenure. Capped by the loan type's min and max amount.
FR-10	Result shows an estimated range and a disclaimer ("indicative only, final approval by lender") with an Apply button that pre-fills the form.

3.3 Apply (Stages 4-6)

ID	Requirement
FR-11	Apply form fields: name, mobile (10-digit Indian), email, city, loan type, amount, monthly income, consent checkbox (customer agrees that details are shared with the partner NBFC and that the team may call). Captcha on submit.
FR-12	Server validation: mobile format, amount within loan type limits, income > 0.
FR-13	Spam control without OTP: captcha on submit, rate limit per IP (max 5 applications per hour), hidden honeypot field and mobile format check. Staff confirms the mobile number on the first call (see FR-30).
FR-14	Application is created after validation and captcha pass. Generate an application number like APP-2026-000001.
FR-15	Duplicate rule: same mobile and same loan type within 24 hours updates the existing open application instead of creating a new one.
FR-16	If a user is logged in, the application links to the account. If not, it is saved without an account. When the customer later signs up and verifies the same email, earlier applications with that email are linked to the account.

3.4 Document upload (Stages 7-8)

ID	Requirement
FR-17	Document types: PAN, Aadhaar, salary slips (up to 3), bank statement (6 months), other. Required list per loan type comes from config.
FR-18	Allowed files: PDF, JPG, PNG. Max 5 MB each. Check MIME type and extension, rename files to random IDs.
FR-19	Store files in private storage (not a public folder). Serve only through an authenticated endpoint or short-lived signed URL, after a role and ownership check.
FR-20	Document upload needs a logged-in customer. After applying, the Submitted page asks the customer to create an account (name, email, mobile prefilled) to upload documents and track status. Upload stays open until the application is closed.
FR-21	Staff can mark each document Verified or Rejected (with reason). Customer sees the result.
FR-22	Application Submitted page shows the application number and next steps. Customer gets an email confirmation. Team gets a new-lead email.

3.5 Customer dashboard (Stages 9-10)

ID	Requirement
FR-23	Customer signup with name, email, mobile and password. Email verification by link before login. Login with email and password. Forgot-password by email link. Lock the account for 15 minutes after 5 failed attempts.
FR-24	My Applications: list with number, loan type, amount, date and current status.
FR-25	Application detail: status timeline (from status history), uploaded documents with verification state, option to upload more.
FR-26	Profile: view and update name, email, city. Mobile change is allowed; staff re-confirms the number on the next call.

3.6 Admin, manager and staff panel (Stages 11-15)

ID	Requirement
FR-27	Login with email and password for staff, manager, admin. Passwords hashed with bcrypt. Lock the account for 15 minutes after 5 failed attempts.
FR-28	Dashboard: leads today, this week, this month; count by status; unassigned leads; pending follow-ups. Manager and Admin see team totals, Staff see own.
FR-29	Leads list with search (name, mobile, application number) and filters (status, loan type, city, date range, assigned staff). Pagination.
FR-30	Lead detail: customer data, documents, notes, status history, assigned staff, follow-ups. Staff can mark the mobile number as confirmed after the first call.
FR-31	Assignment: Manager or Admin assigns and reassigns a lead. Every assignment is logged. Staff gets an email alert.
FR-32	Status update: allowed transitions per Section 4. Each change is logged with user and time and notifies the customer.
FR-33	Notes and follow-ups: add notes; set follow-up date and time; dashboard lists due follow-ups.
FR-34	Add lead manually (walk-in or phone). Source is stored as walk-in, phone or web.
FR-35	Enquiries: view contact messages and call-back requests, mark as handled.
FR-36	Manager monitoring view: leads per staff, open vs closed, oldest untouched leads, overdue follow-ups.
FR-37	Admin: add, edit, deactivate staff and managers. Edit loan types, rates, amounts, tenures, fees, required documents.

3.7 Reports (Stage 16)

ID	Requirement
FR-38	Reports with date range filter: leads by loan type, city, source, status and staff.
FR-39	Conversion rate: Disbursed / total leads, per staff and per loan type. Average time from New to Contacted.
FR-40	Export leads and reports to CSV (Excel-compatible). Manager and Admin only. Each export is written to the audit log.

3.8 Notifications

ID	Requirement
FR-41	Email: new application (team), assignment (staff), status change and document request (customer), signup verification and password reset (customer), contact and call-back (team).
FR-42	SMS and WhatsApp updates are deferred to Phase 2 (they need DLT registration and a provider). Email only for now.
FR-43	Send notifications through a background task or queue so a provider failure does not block the form. Lead alerts go to the info mailbox. System emails (verification, status) go from a no-reply address on the client domain with SPF, DKIM and DMARC set.

4. Status Workflow

Status	Meaning	Set by
Submitted	Application received and validated	System
Assigned	Lead given to a staff member	Manager / Admin
Contacted	Staff has spoken to the customer	Staff
Documents Pending	Waiting for customer documents	Staff

Status	Meaning	Set by
Documents Verified	All required documents checked	Staff
In Process	Application is with the bank/NBFC or under review	Staff
Approved	Loan approved	Staff / Manager
Disbursed	Loan amount released (closed, counts as conversion)	Staff / Manager
Rejected	Application rejected, reason mandatory	Staff / Manager
Not Reachable / Closed	Customer not responding or withdrew, reason mandatory	Staff / Manager

Normal path: Submitted, Assigned, Contacted, Documents Pending, Documents Verified, In Process, Approved, Disbursed. Rejected and Closed can be set from any open status. Only Manager and Admin can reopen a closed lead. Reject invalid jumps on the backend.

5. Data Model

Table	Main fields
users	id, name, email, mobile, password_hash, email_verified, role, is_active, failed_attempts, locked_until, created_at
auth_tokens	id, user_id, token_hash, purpose (verify_email/reset_password), expires_at, used_at, created_at
loan_types	id, name, slug, min_rate, min_amount, max_amount, min_tenure, max_tenure, fees, eligibility_text, required_docs (json), is_active
applications	id, app_number, user_id, name, mobile, email, city, loan_type_id, amount, income, existing_emi, status, assigned_to, source, mobile_confirmed, consent, consent_text_version, consent_at, created_at, updated_at
documents	id, application_id, doc_type, storage_key, original_name, mime, size, verification (pending/verified/rejected), reject_reason, uploaded_at
status_history	id, application_id, old_status, new_status, reason, changed_by, created_at
assignments	id, application_id, assigned_to, assigned_by, created_at
notes	id, application_id, user_id, note, created_at
followups	id, application_id, user_id, due_at, done, created_at
enquiries	id, type (contact/callback), name, mobile, email, message, handled, created_at
audit_log	id, user_id, action, entity, entity_id, ip, created_at

Index: applications(mobile), applications(status), applications(assigned_to), applications(created_at), applications(app_number unique). Use Alembic for migrations.

6. API Overview (REST, prefix /api/v1)

Module	Endpoints
Public	GET /loan-types, POST /enquiries, POST /callbacks
Auth	POST /auth/signup, POST /auth/verify-email, POST /auth/login (all roles), POST /auth/forgot-password, POST /auth/reset-password, POST /auth/refresh, GET /me
Applications (customer)	POST /applications, GET /me/applications, GET /me/applications/{id}, POST /applications/{id}/documents
Leads (team)	GET /leads, GET /leads/{id}, POST /leads, PATCH /leads/{id}/status, POST /leads/{id}/assign, POST /leads/{id}/notes, POST /leads/{id}/followups
Documents	GET /documents/{id}/file (authorised), PATCH /documents/{id}/verify
Admin	GET/POST/PATCH /users, GET/POST/PATCH /loan-types, GET /enquiries, PATCH /enquiries/{id}

Module	Endpoints
Reports	GET /reports/summary, GET /reports/by-staff, GET /reports/by-loan-type, GET /reports/export.csv

7. Non-Functional and Security Requirements

- HTTPS only. JWT access token (15-30 min) and refresh token. bcrypt for passwords.
- Role check on every endpoint and ownership check on every object (customer sees only own data, staff only assigned leads).
- Rate limiting on login, signup, password reset and form endpoints. Captcha on public forms. CORS limited to the site domain.
- Validate and sanitise all input. Use parameterised queries (SQLAlchemy). Escape output in React.
- Documents (KYC, Aadhaar) are sensitive: private storage, access only after authorisation, access logged, no public URLs, never log full Aadhaar numbers.
- Privacy policy and consent text visible before submit. Delete or anonymise data on valid request.
- Daily database backup. Environment variables for secrets (never in git).
- Pages load under 3 seconds on mobile. Works on current Chrome, Edge, Firefox, Safari.

8. Build Order (common first)

Step	Work	Depends on client?
1	Project setup, database, migrations, auth, roles, audit log	No
2	Loan types API and admin editing, seeded with sample data	Rates later
3	Public pages, EMI calculator, eligibility checker	Content later
4	Apply form, captcha, application creation, duplicate rule	No
5	Document upload, private storage, verification	No
6	Customer dashboard and status timeline	No
7	Admin panel: leads, assignment, status workflow, notes, follow-ups	No
8	Manager monitoring view and reports, CSV export	No
9	Email notifications, signup, email verification, password reset	SMTP account
10	Config-driven content: LSP text, partner NBFC, Grievance Officer, consent line, theme, logo	Yes (NBFC name and rates, phone, officer)
11	Testing, deployment, SSL	Hosting access

9. Open Items from Client

- Partner NBFC: name, website link, product list and rate sheet (most important).
- Final theme (blue or green), phone and WhatsApp number.
- Grievance Officer: name and email (phone optional).
- Hosting, SMTP details for the info mailbox, storage choice for documents.
- Whether Aadhaar copy is really needed (can be reduced to PAN plus address proof).

10. Out of Scope for Now

- Payment gateway, loan repayment and EMI collection
- Blog and customer reviews page
- OTP verification, SMS and WhatsApp automated updates (Phase 2)

- Credit score check, bank API integrations, e-sign
- Super Admin role and advanced permission editor
- Mobile app, multi-language

11. Acceptance Criteria

1. A visitor applies without login and sees the submitted page and application number. After signup and email verification the customer uploads documents.
2. Customer can log in with email and password and track status changes made by staff.
3. Manager assigns a lead; only the assigned staff (plus Manager/Admin) can open it; invalid status jumps are rejected.
4. Documents cannot be opened without login and permission.
5. Reports match the lead data and export to CSV.
6. Emails are sent for the events in FR-41.
7. Partner NBFC name, Grievance Officer details, privacy policy and consent line are visible and come from config.
8. Site works on mobile and desktop over HTTPS.